

Снова уязвимые шаблоны ADCS: детектируем технику ESC15

 purpleshift.io/ru/articles/2024-10-31-esc15

31 октября 2024 г.

```
Certificate Services loaded a template.

WebServer v4.1 (Schema V1)

CN=WebServer,CN=Certificate Templates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=test,DC=local

Template Information:
  Template Content:
  flags = 0x10241 (66113)
  CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT -- 0x1
  CT_FLAG_MACHINE_TYPE -- 0x40 (64)
  CT_FLAG_ADD_TEMPLATE_NAME -- 0x200 (512)
  CT_FLAG_IS_DEFAULT -- 0x10000 (65536)

msPKI-Private-Key-Flag = 0x0 (0)
CTPRIVATEKEY_FLAG_ATTEST_NONE -- 0x0
TEMPLATE_SERVER_VER_NONE << CTPRIVATEKEY_FLAG_SERVER
```

1. [Статьи](#)/

В начале октября была обнаружена очередная возможность повышения привилегий с помощью шаблонов сертификатов ADCS - техника [ESC15](#). Уязвимыми являются шаблоны сертификатов с 1-й версией схемы и возможностью указать subjectAltName (SAN) в CSR. Также нужно знать учётные данные пользователя с правами Enroll на уязвимый шаблон.

Одним из встроенных уязвимых шаблонов является **WebServer** (Version:1 и CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT). По-умолчанию, запрашивать сертификаты, используя этот шаблон, могут только Domain- и Enterprise-администраторы. Но по нашему опыту, пользователи часто меняют права на него, и нередко можно встретить там даже Authenticated Users.

Суть эксплуатации

При наличии у сертификата расширения **Application Policies** и **Extended Key Usage (EKU)**, домен-контроллер [предпочтёт](#) верить ECU из "Application Policies".

То есть при запросе сертификата, используя уязвимый шаблон, атакующий может добавить ECU "Client Authentication" в поле "Application Policies", добавить администратора домена в SAN и, получив сертификат, успешно запросить TGT для

этого администратора. Получается очень похоже на технику ESC1. Единственное ограничение - это возможность аутентификации только по schannel на LDAP.

Также атакующий может добавить ECU "Certificate Request Agent" в поле "Application Policies" и использовать полученный сертификат для запроса ещё одного, но уже на любого пользователя, как это реализовано в технике ESC3. Либо добавить "Code Signing" в "Application Policies" - и использовать сертификат для подписи файлов.

Для эксплуатации можно использовать утилиту certipy ([PR](#) ещё не заапрувлен) либо [PSCertificateEnrollment](#).

Как детектировать

Для детектирования уязвимых шаблонов можно использовать событие с EventID 4898 (лучше включить флаг [EDITF_AUDITCERTTEMPLATELOAD](#)), абстрактно запрос выглядит так:

```
EventID:4898 AND TemplateContent:"CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT" AND  
TemplateSchemaVersion:1
```

```

Certificate Services loaded a template.

WebServer v4.1 (Schema V1)

CN=WebServer,CN=Certificate Templates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=test,DC=local

Template Information:
  Template Content:
  flags = 0x10241 (66113)
  CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT -- 0x1
  CT_FLAG_MACHINE_TYPE -- 0x40 (64)
  CT_FLAG_ADD_TEMPLATE_NAME -- 0x200 (512)
  CT_FLAG_IS_DEFAULT -- 0x10000 (65536)

msPKI-Private-Key-Flag = 0x0 (0)
CTPRIVATEKEY_FLAG_ATTEST_NONE -- 0x0
TEMPLATE_SERVER_VER_NONE < CTPRIVATEKEY_FLAG_SERVERVERSION_SHIFT -- 0x0
TEMPLATE_CLIENT_VER_NONE < CTPRIVATEKEY_FLAG_CLIENTVERSION_SHIFT -- 0x0

msPKI-Certificate-Name-Flag = 0x1 (1)
CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT -- 0x1

msPKI-Enrollment-Flag = 0x0 (0)

msPKI-Template-Schema-Version = 1

revision = 4

msPKI-Template-Minor-Revision = 1

pKIDefaultKeySpec = 1

pKIExpirationPeriod = 2 Years

pKIOverlapPeriod = 6 Weeks

cn = WebServer

distinguishedName = WebServer

Security Descriptor: O:S-1-5-21-837510782-1078370389-2529773014-
519G:S-1-5-21-837510782-1078370389-2529773014-519D:PAI(OA;;RPWPCR;0e10c968-78fb-11d2-
90d4-00c04f79dc55;;DA)(OA;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;S-1-5-21-
837510782-1078370389-2529773014-519)(A;;CCDCLCSWRPWPDTLOSDRCWDWO;;;DA)
(A;;CCDCLCSWRPWPDTLOSDRCWDWO;;;S-1-5-21-837510782-1078370389-2529773014-519)
(A;;LCRPLORC;;;AU)

Allow TEST\Domain Admins
  Enroll
Allow TEST\Enterprise Admins
  Enroll
Allow(0x000f00ff) TEST\Domain Admins
  Full Control
Allow(0x000f00ff) TEST\Enterprise Admins
  Full Control
Allow(0x00020094) NT AUTHORITY\Authenticated Users
  Read

```

Также можно воспользоваться обновленной в рамках [PR](#) командой find утилиты certipy, либо LDAP запросом:

```

Get-ADObject -LDAPFilter '(&(objectclass=pkicertificatetemplate)(!(mspki-
enrollment-flag:1.2.840.113556.1.4.804:=2))(|(mspki-ra-signature=0)(!(mspki-ra-
signature=*)))(mspki-template-schema-version=1)(mspki-certificate-name-
flag:1.2.840.113556.1.4.804:=1))' -SearchBase 'CN=Configuration,DC=test,DC=local' -
Properties DisplayName

```

При использовании утилиты certipy, в атрибутах запроса события 4887 будет [специфичное содержание](#).

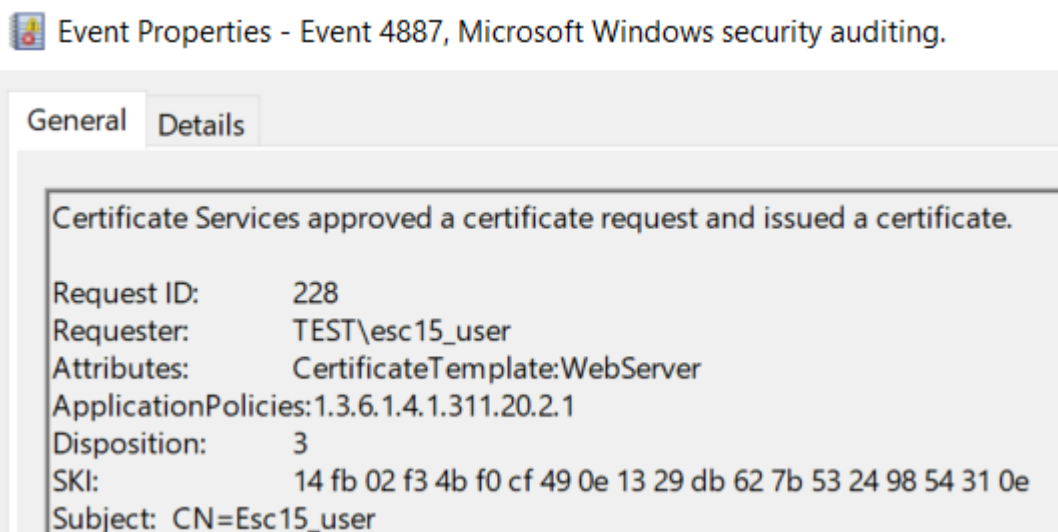
```

718         # Construct attributes list
719         attributes = ["CertificateTemplate:%s" % self.template]
720
721         if self.alt_upn is not None or self.alt_dns is not None:
722             san = []
723             if self.alt_dns:
724                 san.append("dns=%s" % self.alt_dns)
725             if self.alt_upn:
726                 san.append("upn=%s" % self.alt_upn)
727
728             attributes.append("SAN:%s" % "&".join(san))
729
730         if self.application_policies:
731             policy_string = "&".join(self.application_policies)
732             attributes.append(f"ApplicationPolicies:{policy_string}")
733
734         cert = self.interface.request(csr, attributes)

```

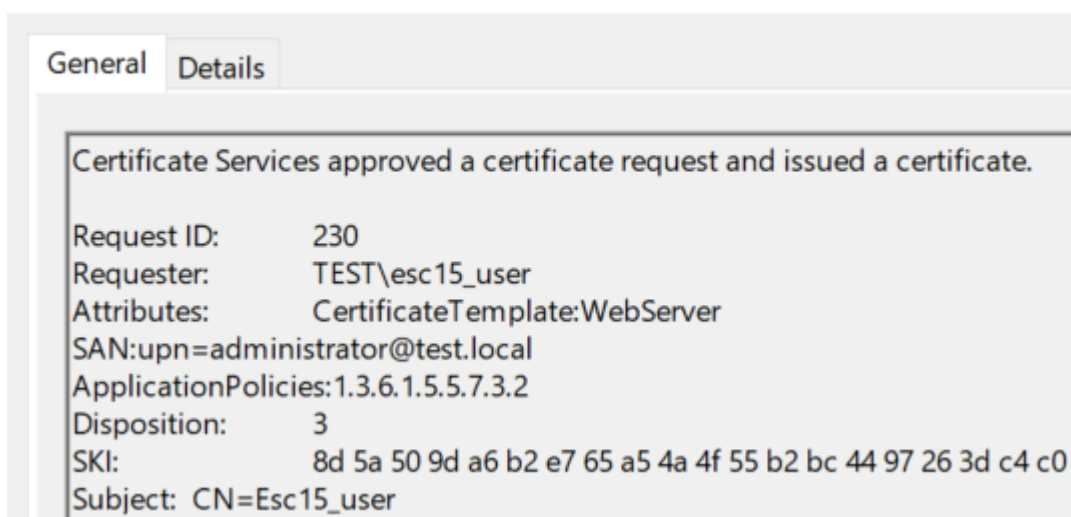
Полагаться на это при детектировании запроса нельзя, так как это необязательное поле в CSR. Например, при добавлении Application Policies в поле атрибутов мы увидим имя шаблона и OID добавленной политики:

CertificateTemplate:WebServer ApplicationPolicies:1.3.6.1.4.1.311.20.2.1



Если запросить сертификат с SAN, то выглядеть это будет уже следующим образом:

CertificateTemplate:WebServer SAN:upn=administrator@test.local
 ApplicationPolicies:1.3.6.1.5.5.7.3.2



Если есть возможность получать события из БД ADCS, то там подобные запросы выглядят так:

```

Request Attributes: 2
2 attributes:

Attribute[0]: 1.2.840.113549.1.9.14 (Certificate Extensions)
Value[0][0], Length = 1f
Certificate Extensions: 1
1.3.6.1.4.1.311.21.10: Flags = 0, Length = e
Application Policies
[1]Application Certificate Policy:
Policy Identifier=Client Authentication

Attribute[1]: 1.2.840.113549.1.9.14 (Certificate Extensions)
Value[1][0], Length = 37
Certificate Extensions: 1
2.5.29.17: Flags = 0, Length = 2c
Subject Alternative Name
Other Name:
Principal Name=administrator@test.local

Request Attributes: "CertificateTemplate:WebServer
SAN:upn=administrator@test.local
ApplicationPolicies:1.3.6.1.5.5.7.3.2"
0000 43 00 65 00 72 00 74 00 69 00 66 00 69 00 63 00 C.e.r.t.i.f.i.c.
0010 61 00 74 00 65 00 54 00 65 00 6d 00 70 00 6c 00 a.t.e.T.e.m.p.l.
0020 61 00 74 00 65 00 3a 00 57 00 65 00 62 00 53 00 a.t.e.:.W.e.b.S.
0030 65 00 72 00 76 00 65 00 72 00 0a 00 53 00 41 00 e.r.v.e.r...S.A.
0040 4e 00 3a 00 75 00 70 00 6e 00 3d 00 61 00 64 00 N.:.u.p.n.=.a.d.
0050 6d 00 69 00 6e 00 69 00 73 00 74 00 72 00 61 00 m.i.n.i.s.t.r.a.
0060 74 00 6f 00 72 00 40 00 74 00 65 00 73 00 74 00 t.o.r.@.t.e.s.t.
0070 2e 00 6c 00 6f 00 63 00 61 00 6c 00 0a 00 41 00 ..l.o.c.a.l...A.
0080 70 00 70 00 6c 00 69 00 63 00 61 00 74 00 69 00 p.p.l.i.c.a.t.i.
0090 6f 00 6e 00 50 00 6f 00 6c 00 69 00 63 00 69 00 o.n.P.o.l.i.c.i.
00a0 65 00 73 00 3a 00 31 00 2e 00 33 00 2e 00 36 00 e.s...1...3...6.
00b0 2e 00 31 00 2e 00 35 00 2e 00 35 00 2e 00 37 00 ..1...5...5...7.
00c0 2e 00 33 00 2e 00 32 00 ..3...2.

Certificate Template: "WebServer"
0000 57 00 65 00 62 00 53 00 65 00 72 00 76 00 65 00 W.e.b.S.e.r.v.e.
0010 72 00 r.

X509 Certificate:
Version: 3
Serial Number: 7700000e63712e7b9c6a303ec000000000e6
Signature Algorithm:
Algorithm ObjectID: 1.2.840.113549.1.1.11 sha256RSA
Algorithm Parameters:
05 00
Issuer:
CN=test-DC-CA
DC=test
DC=local
Name Hash(sha1): e6b4a96893e27f05ecaa07ab6b6043bc2a5e951d
Name Hash(md5): 5548f7174c41e9e8b3e49b5aed2fc60a
NotBefore: 10/22/2024 13:41
NotAfter: 10/22/2026 13:41

Subject:
CN=Esc15 user
Name Hash(sha1): 1033f14faa769eed64d9fcc9d6277ca3abc4921f
Name Hash(md5): 4193fad00ab980046d6f2913e56239f3

Public Key Algorithm:
Algorithm ObjectID: 1.2.840.113549.1.1.1 RSA
Algorithm Parameters:
05 00
Certificate Extensions: 9
1.3.6.1.4.1.311.21.10: Flags = 0, Length = e
Application Policies
[1]Application Certificate Policy:
Policy Identifier=Client Authentication

2.5.29.17: Flags = 0, Length = 2c
Subject Alternative Name
Other Name:
Principal Name=administrator@test.local

2.5.29.14: Flags = 0, Length = 16
Subject Key Identifier
8d5a509da6b2e765a54a4f55b2bc4497263dc4c0

2.5.29.35: Flags = 0, Length = 18
Authority Key Identifier
KeyID=8c4d55aee28d5616c95b002f6b2e4a3eb5590fac

```

Посмотреть, как это выглядит в БД, можно с помощью certutil:

```
certutil.exe -v -view -restrict "RequestID=230" -out
Request.RequestID,Request.RawRequest,Request.RequestAttributes,CertificateTemplate,
RawCertificate
```

Что делать после обнаружения уязвимых шаблонов

Есть несколько вариантов действий:

1. Удалить неиспользуемые шаблоны или отключить их. Можно сделать это, используя скрипт [ESC15.ps1](#) и [Unpublish-SchemaV1Templates.ps1](#)
2. Клонировать шаблон, если он необходим. При клонировании, версия схемы нового шаблона автоматически повысится до 2ой и новый шаблон не будет уязвимым к данной технике.
3. Заполнить атрибут [msPKI-Certificate-Application-Policy](#) необходимыми для шаблона ECU из атрибута [pKIEntendedKeyUsage](#), используя скрипт [Remediate-ESC15.ps1](#). В этом случае, при запросе сертификата, CA добавит в Application Policy сертификата ECU из шаблона - и атакующий не сможет добавить свои ECU из запроса.

Этот способ не сработает для шаблонов, у которых атрибуты msPKI-Certificate-Application-Policy и pKIEntendedKeyUsage специально выставлены в Null, например SubCA, CA, CrossCA. Следить за тем, кто может выпускать сертификаты, используя подобные шаблоны, нужно особенно внимательно.

4. Если вы уверены, что данное расширение вам не нужно, то можно отключить добавление Application Policies к сертификату:

```
certutil -setreg policy\DisableExtensionList +1.3.6.1.4.1.311.21.10
```

Но в любом случае необходимо проверить выпущенные сертификаты с использованием уязвимых шаблонов.